MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 025 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · ACCESS CONTROL

3.5.3: The MFA Control Most Programs Think They Already Passed

NIST 800-171 3.5.3 requires MFA for three scopes, not one. Most programs cover network logins and miss privileged local access - the one assessors test first.

BY **MAXINE** READING TIME · 5 MIN MFA · ACCESS-CONTROL · NIST-800-171 · SPRS

The assessor's laptop is open before the interview starts, and the objective list is already loaded against your system security plan's claims for 3.5.3. Programs walk into this room convinced they cleared it months ago. Somebody remembers the Duo rollout. Somebody else mentions that the VPN pushes a code to a phone. What they are picturing is one scope of the three the requirement actually names, and the assessor is about to walk through all three in order.

FIELD COPY
ISSUE Nº 025
MFA

First question: log into your email

The demonstration opens easy on purpose. Open a laptop, sign into the tenant, produce the second factor. Microsoft 365 asks for a push notification, the notification arrives, the objective is met. This is network access to a non-privileged account, the third scope in the requirement's text, and it is the scope nearly every program answers when it says "we have MFA." The assessor makes a note and moves on, because this was never the interesting question.

3

DISTINCT SCOPES INSIDE 3.5.3 - MOST PROGRAMS HAVE IMPLEMENTED ONE

5

SPRS POINTS ON THE LINE, AND NOT POA&M-ELIGIBLE IF ANY SCOPE IS UNMET

2

REQUIREMENTS IN THE DOD ASSESSMENT METHODOLOGY THAT SCORE ON A SLIDING SCALE, NOT ALL-OR-NOTHING

Second question: log in as the domain admin

Now the account changes. The assessor wants to see an administrator authenticate to a server or a management console over the network, and this is where the real spread in program maturity shows up. A shop running conditional access or privileged identity management produces a second factor here too, often a stronger one than the email demo, because someone understood that admin credentials deserved more scrutiny than a mailbox. This is network access to a privileged account, and a program that built its MFA program around "protect the admins first" clears it cleanly. The confidence in the room usually peaks right here.

Third question: walk to the server

The console is the path that bypasses every network control you have documented.

The assessor does not ask to see the VPN again. They ask to see the same administrator log in from the machine itself: the console attached to the server, the keyboard on the rack, the login screen on the hypervisor host. No VPN client runs there. No conditional access policy evaluates a login that never touches the network stack it was written to watch. In a program that built MFA into its identity provider and stopped, this is a local password prompt and nothing else, because the identity provider never gets asked. That is the entire objection this scope exists to answer, and it is the one that ninety percent of "we already have MFA" claims did not anticipate. Local access to a privileged account is a distinct requirement inside 3.5.3, not a variant of the network scope, and it is usually the first finding an assessor writes.

◆ WHAT COUNTS AS LOCAL ACCESS

The console attached to the server, the keyboard on the rack, the hypervisor's own login screen, an out-of-band management port. Remote desktop into that same account over the network is a different scope, one your VPN's MFA may already answer.

The account nobody put in the ticket

Once the console gap is open, the questions that follow it get sharper. What about the service account that runs the backup job. What about the account IT keeps for the morning the identity provider itself is down. Break-glass and service accounts are privileged accounts under the same definition as the domain admin's named login, which means the same three-scope test applies to them, and they are usually the ones a program never enrolled in anything, because automation cannot answer a push notification and an emergency account is, by design, meant to work when everything else has failed. Those are legitimate constraints, not exemptions, and the requirement does not carve one out for convenience. This is the point in the session where a program that felt solid twenty minutes ago starts doing arithmetic in its head.

The math the program didn't know it had

Here is the detail that should change what gets fixed first, and almost nobody in the room knows it going in: 3.5.3 is one of only two requirements in the DoD Assessment Methodology that does not score all or nothing. Everywhere else in the 110, a control is implemented or it isn't, and partial work banks zero points. 3.5.3 is a sliding scale - implementing MFA for two of the three scopes banks meaningfully more than implementing it for none, instead of collapsing to the same score as doing nothing. The other exception is 3.13.11, the validated-cryptography requirement Issue Nº 014 already walked through in detail; the mechanics differ but the shape of the exception is the same, and there is no reason to re-argue it here. MacTech's public CMMC reference server publishes the 800-171A objectives behind 3.5.3 and encodes that sliding-scale rule directly, which is the kind of thing worth checking rather than assuming.

The practical consequence is sequencing. A program facing this finding for the first time should close the local-privileged-access gap before it worries about hardening an already-covered scope further, because that is the piece worth the most partial credit per hour of work - not because it is the easiest technically, but because the SPRS arithmetic rewards exactly that move on this one control and on no other.

Why partial credit doesn't buy a delay

The sliding scale is real, and it is also not an invitation to plan around this the way a program plans around a lower-weight gap. 3.5.3 carries the full five-point weight, and a five-point requirement is not eligible for a POA&M at certification the way a lighter-weight gap can be. Partial implementation improves the number an assessor sees today. It does not create room to finish the remaining scope after the assessment is scheduled. All three scopes have to be closed, and closed before the assessor sits down, not promised for the quarter after.

None of this gets resolved by writing a stronger MFA policy. The 800-171A objectives are testable, and the test an assessor runs is a demonstration, not a document review - they ask you to log in, and then they ask you to log in the other way. A program that wants to know which of its three scopes would fail that second question before a C3PAO asks it can run a readiness check against the same objectives and find out on its own schedule instead of the assessor's. ◆